BACKEND IMPLEMENTATION REPORT

Apex Care Technologies

Next.js as the server. MongoDB as the only data store. What was built, how it was verified, and what is still open.

72	17	300	0
API operations	MongoDB collections	automated tests	production dependency
27 public · 45 admin	plus GridFS file storage	all passing	vulnerabilities

Prepared 18 October 2026 · Next.js 16.4.2 · MongoDB 8 · Mongoose 9 · Node 24
Companion documents: `features.readme.md` (full inventory) and `README.md` (how to run)

1. Summary

The site's UI was already built. This work connects it to a real backend: every page now reads its content from **MongoDB**, every form writes to it, and an authenticated admin API manages all of it. Next.js is both the website and the API server, so there is nothing else to deploy.

What changed in this final phase

- **Moved to your local Node** (no Docker): one command, `npm run dev:all`, starts MongoDB, a mail catcher, seeds the database and runs the site.
- **Four new features:** customer testimonials with moderation, enquiry tracking, a double opt-in newsletter, and content import/restore.
- **Real-browser testing:** 28 tests drive your installed Chrome through the actual UI (forms, search, tracker, newsletter, lightbox, mobile, dark mode, analytics). They confirm the site works as a visitor would use it; the failures they surfaced along the way were test-harness issues, not site bugs.
- **Security upgrade:** Next.js 16.3.6 → 16.4.2 fixed two advisories (cache poisoning, image-optimiser SSRF). Production audit is now clean.
- **Bugs found by the tests and fixed** (listed in section 7).

Result

Check	Result
Type-check (`tsc --noEmit`)	**clean**
Lint (`eslint`)	**clean**
Production build	**passes, needs no database**
Automated tests (`npm test`)	**300 / 300 pass, ~66 s**
Browser tests in real Chrome	**28 / 28 pass, stable across repeated runs**
`npm audit --omit=dev`	**0 vulnerabilities**
Full-tree `npm audit`	**5 high, dev-only lint tooling (see section 9)**

> **Read this first:** there is **no admin web interface**. All administration (content, enquiries, users, settings) goes through the authenticated API. That is the main thing left to build, and the API is designed for it.

2. Audit: what existed and what was missing

Before adding anything, the existing code was checked against the goal of "every site feature backed by MongoDB, and every backend feature that makes sense".

Area	Status at start of this phase	Action taken
Content from MongoDB (products, surveys, training, gallery, logos, leaders, settings)	**Done**	Verified; kept
Enquiry form → MongoDB, email, webhook, spam defences	**Done**	Verified; kept
Auth, roles, sessions, CSRF, lockout	**Done**	Verified; kept
Admin CRUD, media (GridFS), analytics, audit, export, cron	**Done**	Verified; kept
Ran only inside Docker	**Blocker for you**	Rebuilt to run on local Node with an npm-managed MongoDB
Customers could not submit testimonials	Missing	**Added** (moderated)
Customers could not check an enquiry's status	Missing	**Added**
No newsletter / consent capture	Missing	**Added** (double opt-in)
Export existed but could not be restored	Gap	**Added** import / restore
UI only checked at HTML level, never in a browser	Gap	**Added** 28 real-Chrome tests
Dependencies with known advisories (Next.js)	Gap	**Upgraded** to patched 16.4.2
Admin web UI	Missing	**Not built** (API only)

3. Features implemented

Site content

- 39 products, 5 groups, 9 surveys, 10 training programmes, gallery, logos, leadership, testimonials
- Editable site settings (contact details, emails, hero text, certificates, catalogue)
- Live home-page statistics
- Edits appear on the live site instantly (tag-invalidated cache)
- Dynamic sitemap, SEO metadata, JSON-LD

Enquiries

- Validated form with atomic references `ENQ-2026-000123`
- Email to sales + acknowledgement to customer + signed webhook
- Per-channel delivery status, retry, resend
- Anti-spam: signed token, honeypot, scoring, duplicate collapse, rate limits
- Admin inbox: filters, search, status history, first-response time, assign, tags, notes, bulk actions, CSV export

Customer enquiry tracking NEW

- Reference + mobile number → progress and timeline
- Internal notes never exposed; wrong reference and wrong number look identical

Search

- Products, surveys and training; ranked; injection-safe
- Live search dialog in the header

Testimonials NEW

- Public form on the About page → stored *unpublished*, team emailed
- Approve = publish, reject = delete; submitter email stays private

Newsletter NEW

- Double opt-in; links open a confirm page so mail scanners cannot subscribe/unsubscribe anyone
- One-click unsubscribe; admin list, CSV export, erasure
- Same reply for new / pending / existing (no list probing)

Media (GridFS)

- Content sniffed from file bytes; SVG/HTML/executables rejected
- SHA-256 de-duplication; immutable caching; ETag
- Refuses to delete files still in use
- Tracked, replaceable catalogue download

Analytics

- Cookie-less, no raw IPs, daily-rotating hashed visitor id
- Respects Do Not Track / Global Privacy Control
- Conversion rate, trends, top pages/products/searches, CTA clicks

Operations

- Audit log, dashboard, content export and **import/restore** NEW, health check, cron retry

4. Security and reliability

Concern	Measure
Passwords	scrypt (per-user salt, versioned format); 12+ char policy; no common or email-based passwords
Sessions	Random token; only its SHA-256 is stored; HttpOnly, SameSite=Lax (Secure on https); 7-day sliding expiry; revocable per device
Brute force	Per-IP limit, per-IP+email limit, account lockout after 10 failures; identical errors and equalised CPU for unknown emails
CSRF	Origin / Sec-Fetch-Site check on cookie-authenticated writes (not needed for Bearer clients)
Access control	3 roles, 12 permissions; last administrator and acting user protected; role changes end sessions
Input	Every body and query validated with Zod; unknown fields rejected; typed queries (no NoSQL operators from users); searches regex-escaped
Output	HTML-escaped emails; CRLF/header-injection guarded; JSON-LD escaped; CSV formula-injection neutralised
Uploads	Byte-level type check, size caps, sandboxed CSP and nosniff on served files
Abuse	MongoDB-backed rate limits (survive restarts, work across servers); honeypot + signed tokens + spam scoring on every public form
Privacy	No raw IPs; analytics visitor ids rotate daily; consent-based newsletter; erasure endpoint; automatic data expiry (see below)
Data retention	TTL indexes: sessions, rate-limit windows, analytics (400 d), audit (730 d), spam enquiries (30 d), unconfirmed subscribers (14 d)
Failure handling	Database outage → clean 503; failed emails/webhooks recorded and retried (max 5)

5. API surface (72 operations)

Public: 27

Area	Endpoints
Content	`GET /api/settings · stats · products · products/{slug} · product-groups · surveys · surveys/{slug} · training · gallery · testimonials · leaders · logos`
Search & files	`GET /api/search · catalogue · media/{id} · health`
Enquiries	`GET /api/enquiries/token` · `POST /api/enquiries · enquiries/track`
Engagement	`POST /api/testimonials · newsletter/subscribe · analytics/events` · `GET+POST newsletter/confirm · newsletter/unsubscribe`
Ops	`POST /api/cron/notifications` (secret)

Admin: 45 (session cookie or Bearer token)

Area	Operations	Permission
Auth	login, logout, me, change password, list / revoke sessions	any signed-in user
Users	list, create, get, update, reset password, delete	users:manage
Enquiries	list, get, update, delete, notes (add / delete), resend, bulk, CSV export	enquiries:read / write / delete
Content (8 types)	list, create, get, update, delete, reorder, bulk	content:write
Settings	get, update	settings:write
Media	list, upload, usage, update, delete	media:write
Subscribers	list, CSV export, delete	subscribers:read / manage
Insight	dashboard, analytics, audit log	enquiries:read · analytics:read · audit:read
System	content export, content import, cache purge	system:manage

Content types: products, product-groups, surveys, training, gallery, testimonials, logos, leaders. Full table in `features.readme.md`.

6. Verification

`npm test` is hermetic: it starts its own throw-away MongoDB and mail catcher on free ports, builds and serves the app, runs everything, and removes it all. Your development data is never touched.

Suite	Tests	What it proves
Unit	49	Slugs, phone parsing, CSV-injection guard, spam scoring, file sniffing, scrypt, signed tokens, permissions
Public API	38	Every public endpoint, filters, pagination, search, caching and security headers
Enquiries	38	Whole pipeline including **real emails**, spam, rate limits, triage, notes, bulk, CSV
Auth & RBAC	33	Login, enumeration, lockout, sessions, CSRF, role matrix, password change, user management
Content	35	CRUD for all types, **instant public visibility**, integrity rules, settings merge
Engagement	27	Testimonials, tracking, newsletter double opt-in, import / restore
Media	16	GridFS upload and serving, hostile uploads, usage-aware delete, PDF catalogue
Operations	20	Analytics, audit log, export, cron, access control
Infrastructure	10	TTL and unique indexes, seed idempotency, hashing at rest
Webhook	6	HMAC signature, failure → retry → success, attempt cap
Real Chrome	28	All pages free of console errors, broken images and overflow; search; every form; tracker; newsletter; lightbox; mobile; dark mode; SEO; analytics; privacy signal
Total	**300**	**all passing**

Browser tests run headless in Google Chrome via `playwright-core` (an npm library; no browser download). They run with reduced motion because the site honours it and smooth scrolling makes scripted clicks unreliable.

7. Defects found and fixed during testing

Writing tests for the new work uncovered real problems, all now fixed and covered:

Found by	Problem	Impact if shipped
API test	Catalogue download returned a 500 (redirect response had immutable headers)	Every “Download catalogue” link broken
API test	Admin enquiry filters rejected every request (schema helper mismatch)	Inbox filtering unusable
API test	CSV export prefixed phone numbers with an apostrophe	Phone cells looked wrong in Excel
Import test	Error paths reported the wrong row when some items were invalid	Misleading messages during restore
Browser test	Click targets moved during smooth scrolling (test-only), plus third-party Google Map console noise	None for visitors; tests hardened
Type-check	Mongoose 9 typing caused a type-checker out-of-memory crash	Build impossible; fixed at its root
Audit	Next.js 16.3.6 had two security advisories	Cache poisoning and SSRF exposure; upgraded
Review	A planned Docker seed step would have overwritten your macOS `node_modules`	Removed before it ever ran

8. How to run it

```
npm install
npm run dev:all        # MongoDB + mail catcher + seed + site
                       #   site   http://localhost:3000
                       #   mail   http://127.0.0.1:8025
npm test               # all 300 tests, isolated from your dev data
```

Command	Purpose
`npm run seed`	Add missing content and the first admin (never overwrites edits)
`npm run create-admin -- --email … --name … --role editor`	Create another user (set `ADMIN_PASSWORD` in the environment)
`npm test -- auth media`	Run only matching suites
`npm run build && npm start`	Production server (build needs no database)

Going live

- Point `MONGODB_URI` at MongoDB Atlas or your own server; set `SESSION_SECRET`, `PUBLIC_SITE_URL` (https), SMTP settings and `SALES_EMAIL`.
- Run `npm run seed` once and **change the admin password**.
- Put TLS in front; enable `TRUST_PROXY` only behind a proxy that overwrites `X-Forwarded-For`.
- Schedule `POST /api/cron/notifications` every few minutes to retry failed emails/webhooks.
- Back up with `mongodump` and/or `GET /api/admin/export`.

9. Known limits and next steps

Item	Detail	Suggested next step
No admin web UI	All administration is via the authenticated API	Build a dashboard on the existing endpoints (they were designed for it)
Dev-only advisories	5 high-severity items in lint tooling (`eslint-config-next` → glob matchers). The only offered fix downgrades to Next 14. Nothing ships to production.	Re-check after the next `eslint-config-next` release
Browser coverage	Tested in headless Google Chrome only; no screen-reader or cross-browser pass	Add Firefox/Safari runs and an accessibility audit
Docker files	Provided as an optional path but not exercised end-to-end on this machine	Try on a Docker host before relying on them
Newsletter sending	Sign-ups, consent and export are built; campaigns are not sent from here	Export the CSV to a mailing tool, or add a sending job
Product copy	Generic category text from the original site; no standards or certifications claimed	Add real descriptions, features and specs via the API
Proxy trust	Rate limiting reads `X-Forwarded-For`	Set `TRUST_PROXY=false` if exposed without a proxy

Before launch: replace the development secrets in `.env`, change the seeded admin password, confirm SMTP delivers to `SALES_EMAIL`, and review the enquiry recipient list (seeded with the site's published “Enquiry Mail” address).